

RFC-0007

Estratégia de Onboarding e Sincronização via LDAP (Bootstrap Stateless)

Status: Aprovado e Atualizado (v1.1)

Autor: Equipe de Arquitetura

Data: 07/05/2026

Depende de: RFC-0001, RFC-0002, RFC-0005

1. Contexto e Objetivo

A plataforma atende a órgãos governamentais e grandes corporações que já possuem seus próprios diretórios de usuários, como o Active Directory (AD) / LDAP. Exigir o cadastro manual de milhares de servidores e dezenas de secretarias inviabilizaria a implantação do sistema.

Por outro lado, o sincronismo contínuo e bidirecional com o AD costuma engessar a evolução da plataforma, forçando regras de negócio puras (como designar um gestor substituto para o final de semana) a dependerem de lentos chamados de suporte para a equipe de infraestrutura de TI alterar grupos na rede.

Objetivo: Este RFC define a arquitetura de "**Bootstrap Stateless**", estabelecendo como a organização (Tenant) e o servidor público nascem no sistema, e como o cordão umbilical de gerenciamento estrutural com a TI é cortado após a carga inicial, garantindo agilidade operacional e segurança governamental.

2. A Regra do Keycloak: Autenticação Stateless

Para a integração LDAP/AD configurada no Keycloak, a seguinte regra é inegociável:

- O parâmetro **Import Users** ficará sempre configurado como **Off**.

Motivação Técnica e de Segurança:

- O LDAP atuará estritamente como um validador de senhas em tempo real. Se um servidor público for exonerado e a sua conta for desativada no AD da rede governamental, o seu acesso ao sistema de presença será **cortado no exato milissegundo**, sem depender de rotinas de sincronização agendadas (CRON jobs).
 - Como os usuários não são importados para o banco interno do Keycloak, evitamos que o IAM tente sobrescrever as configurações e papéis (roles) locais da nossa plataforma a cada login.
-

3. O Processo de Bootstrap (Carga Inicial Organizacional)

A leitura da árvore do AD não será usada para sincronização contínua de permissões, mas sim como uma "fotografia inicial" (Bootstrap) para poupar trabalho na implantação.

3.1 Mapeamento de Unidades e Vínculos

No momento da criação do Tenant (Organização) na plataforma, um script de inicialização fará a leitura da árvore do AD (ex: OU=UNIDADES, DC=governo, DC=gdfnet, DC=df).

- As pastas/departamentos do AD serão traduzidos fisicamente para registros na tabela **folha_ponto.unidade**.
 - Os usuários contidos nestas pastas terão seus acessos traduzidos para a tabela **folha_ponto.vinculo_usuario**, nascendo com o papel básico de PARTICIPANTE atrelado à organização.
-

4. Interceptação do Primeiro Login (Onboarding Seguro)

Saber em qual unidade o servidor trabalha não resolve o problema de segurança central: garantir que a matrícula de rede que está fazendo login pertence ao CPF correto.

Quando o servidor logar via LDAP pela primeira vez, o Keycloak gerará um identificador técnico (sub) inédito. A arquitetura de segurança atuará da seguinte forma:

1. **Pausa e Redirecionamento (Custom SPI):** O Keycloak, através do Custom Authenticator SPI, notará que o sub do LDAP não possui um CPF atrelado. O login é pausado, um **Action Token** é emitido, e o servidor é redirecionado para a aplicação React.
 2. **Validação 2x2 Governamental:** No React, o servidor informa o seu CPF, aciona a câmera e captura uma selfie. O Spring Boot recebe os dados e faz o cruzamento contra as bases governamentais de fé pública (Serpro / Datavalid).
 3. **Retenção Efêmera e Expurgo:** A imagem da face é utilizada para a extração do Hash Biométrico e, em seguida, armazenada temporariamente em uma quarentena visual (Storage S3) estritamente para fins de auditoria. Essa mídia será objeto de expurgo automatizado (hard delete) após o período configurado, em estrita conformidade com a LGPD.
 4. **Retomada:** Com a validação biográfica e biométrica aprovada, o React devolve o servidor ao Keycloak, que consome o Action Token e emite o *Lightweight Access Token* definitivo.
-

5. O Vínculo da Matrícula LDAP com a Identidade Canônica

É neste momento que a integração técnica se converte em domínio de negócio.

Após a aprovação do Serpro, o backend registrará o **sub** proveniente do LDAP e o atrelará ao ID do CPF na tabela central **seguranca.identidade_acesso**.

O Benefício Resiliente: Isso significa que a integração LDAP é apenas um vetor temporário de acesso. O sistema reconhece a "Pessoa Física X". Se amanhã o órgão mudar do Active Directory para o Google Workspace, o servidor logará pelo Google, informará o CPF, validará a face e o

sistema apenas adicionará o "novo sub do Google" à mesma tabela

seguranca.identidade_acesso. O histórico de folha de ponto do servidor jamais será perdido perante mudanças de infraestrutura de TI.

6. Gestão Contínua e Desacoplamento da TI

O aspecto mais revolucionário da abordagem *Bootstrap* é a liberdade operacional transferida para o negócio (RH / Gestão de Pessoas):

- Após a importação inicial (passo 3), qualquer modificação na estrutura de setores, criação de novas unidades ou identificação de um Gestor Titular passam a ser feitas **exclusivamente no banco de dados da plataforma (PostgreSQL)**.
 - Se um Gestor sai de férias e precisa nomear um "Gestor Substituto", ele não precisará abrir um chamado (ticket) para o Administrador de Redes alterar os grupos do Active Directory.
 - Essa designação ocorrerá nativamente na nossa interface de aplicação, utilizando as tabelas do motor PBAC/ReBAC (**seguranca.excecao_permissao_usuario** e **seguranca.relacionamento**), garantindo delegações temporárias precisas com data de início e fim.
-

7. Resumo de Orquestração do LDAP

1. **Criação do Tenant:** Lê o AD → Popula `folha_ponto.unidade` e `folha_ponto.vinculo_usuario`.
2. **Autenticação:** Valida credencial contra o AD (Stateless).
3. **Onboarding Inicial:** Pausa o login → SPA React → Validação 2x2 de CPF e Face (Serpro) → Popula `seguranca.identidade_acesso`.
4. **Governança:** A partir do dia 1, toda estruturação, delegação e hierarquia de acesso ocorrem no motor local do Spring Boot, blindado de intervenções do setor de infraestrutura da rede.